Report di Penetration Testing e Privilege Escalation

> **Target:** Macchina Virtuale Ubuntu 12.04 (bsides2018)
> **Studente:** Simone Meola
> **Obiettivo:** Acquisizione dei privilegi di root e lettura della flag finale.

1. Scansione di Rete e Ricognizione delle Porte

L'attività di penetration testing è iniziata con una scansione esplorativa della rete per identificare gli host attivi e le porte aperte sul target. L'analisi ha evidenziato la presenza di tre servizi principali in ascolto:

- **FTP (Porta 21):** Servizio di trasferimento file.
- **SSH (Porta 22):** Accesso remoto sicuro via terminale.
- **HTTP (Porta 80):** Servizio web Apache/WordPress.

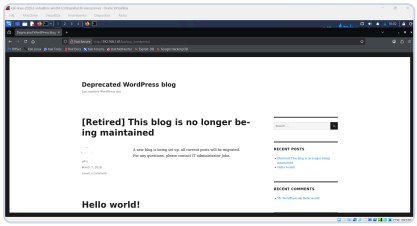


Figura 1: Esplorazione via browser del percorso web attivo sulla porta 80.

2. Enumerazione Web e Analisi delle Directory

Successivamente, ho utilizzato strumenti di enumerazione come Gobuster per individuare directory e file nascosti sulla root del server web.

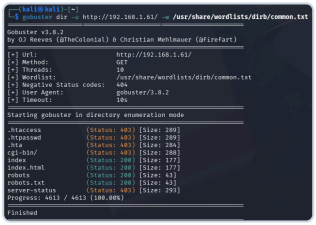


Figura 2: Ricerca di directory e file nascosti tramite Gobuster.

L'analisi ha rivelato una cartella di backup contenente un'installazione di WordPress alla versione 4.5, confermata anche dalla lettura del file `readme.html`.



Figura 3: Verifica della versione di WordPress tramite il file readme.

3. Sfruttamento e Iniezione della Web Shell

Individuata la versione di WordPress 4.5, ho verificato le vulnerabilità note tramite Searchsploit. Successivamente, accedendo al pannello di amministrazione tramite credenziali di backup, ho modificato il file del tema (`footer.php`) inserendo una backdoor PHP per eseguire comandi.

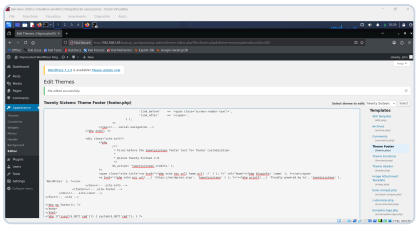


Figura 4: Inserimento della web shell nel file footer.php di WordPress.

Tramite Netcat e la web shell attiva, ho stabilito una connessione ottenendo una sessione interattiva come utente limitato `www-data`.

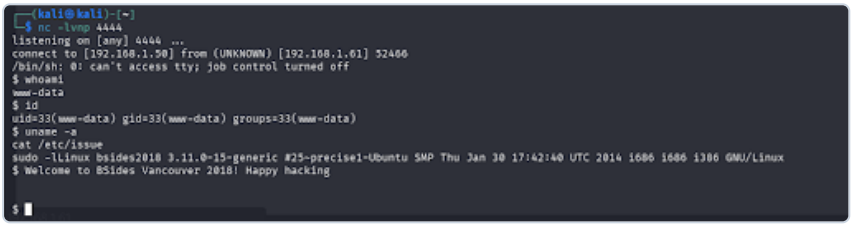


Figura 5: Apertura della reverse shell e verifica dei dettagli di sistema con `uname` e `id`.

4. Privilege Escalation e Ottenimento di Root

Analizzando il sistema, ho individuato un file di script di pulizia (`/usr/local/bin/cleanup`) eseguito ogni minuto da root e globalmente scrivibile (`-rwxrwxrwx`). Ho sovrascritto lo script inserendo un comando per impostare il bit SUID su `/bin/bash`.

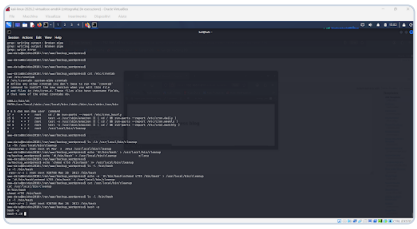


Figura 6: Modifica dello script di cleanup per concedere i permessi SUID a bash.

Al successivo ciclo del cronjob, eseguendo `bash -p`, ho ottenuto con successo i privilegi effettivi di **root** (`uid=0`), leggendo infine la flag conclusiva nella cartella `/root/flag.txt`.

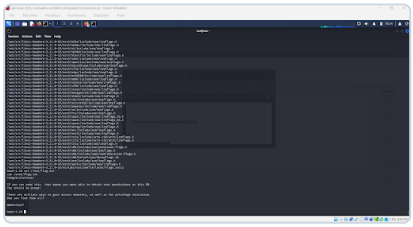


Figura 7: Conquista della macchina e visualizzazione della flag di successo.